

UNBREAKING THE IPHONE

BOOTCHAIN REVERSAL, SEP SABOTAGE, AND THE IOS KERNEL FRONTIER

Jack Sessions

WHAT IS THIS TALK

Live IOS demos (6) in total!!!
Meme, logs and kernel panics
A chance to see persistence actually explained
Watch Dogs Cosplay
Interactive (Hackle-Friendly, soundboard armed)

WHAT IS THIS TALK IS NOT

A polished corporate deck with 180 slides

A full jailbreak walkthrough (if need that go to nullcon)

“All exploits revealed” (sorry, not today)

A quiet academic lecture (nah, we’re memeing)

THANKS TO MY SPONSOR



ABOUT ME

- Computer Science Student #still broke :(
- Mobile Security + Forensics/Counterintelligence "Researcher"
- Still waiting for Ubisoft to hire me for Watch_Dogs 4
- Rap Battle Enjoyer (yes, there's one later)
- CyberSec Youtuber ~ @Jack Sessions
- Failed SoundCloud Rapper
- Not (yet) on an Interpol watchlist... probably



SO WHY IOS?

Most "Secure" Phone

Its Private

**Almost no one
talks about it...**



IOS REALITY

CVE-2025-24126

An input validation issue was addressed. This issue is fixed in visionOS 2.3, iOS 18.3 and iPadOS 18.3, macOS 15.3, watchOS 11.3, tvOS 18.3. An attacker on the local network may be able to cause unexpected system term corrupt process memory.

Source: Apple Inc.

CVE-2024-54542

An authentication issue was addressed with improved state management. This issue is fixed in Safari 18.2, ma 15.2, watchOS 11.2, iOS 18.2 and iPadOS 18.2. Private Browsing tabs may be accessed without authentication.

Source: Apple Inc.

CVE-2025-24211

This issue was addressed with improved memory handling. This issue is fixed in visionOS 2.4, macOS Ventura 18.4, iPadOS 17.7.6, iOS 18.4 and iPadOS 18.4, macOS Sequoia 15.4, macOS Sonoma 14.7.5. Processing a maliciously crafted video file may lead to unexpected app termination or corrupt process memory.

Source: Apple Inc.

CVE-2025-24190

The issue was addressed with improved memory handling. This issue is fixed in visionOS 2.4, macOS Ventura 18.4, iPadOS 17.7.6, iOS 18.4 and iPadOS 18.4, macOS Sequoia 15.4, macOS Sonoma 14.7.5. Processing a maliciously crafted video file may lead to unexpected app termination or corrupt process memory.

Source: Apple Inc.

CVE-2025-24178

This issue was addressed through improved state management. This issue is fixed in macOS Ventura 13.7, iPadOS 17.7.6, iOS 18.4 and iPadOS 18.4, macOS Sequoia 15.4, macOS Sonoma 14.7.5. An app may be able to escape its sandbox.

Source: Apple Inc.



asus spyware and how does it work?

25-43234

memory corruption issues were addressed with improved memory handling. This issue is fixed in visionOS 2.6, iPadOS 18.6, tvOS 18.6, macOS Sequoia 15.6, visionOS 2.6. Processing a maliciously crafted file may lead to unexpected app termination.

Source: Apple Inc.

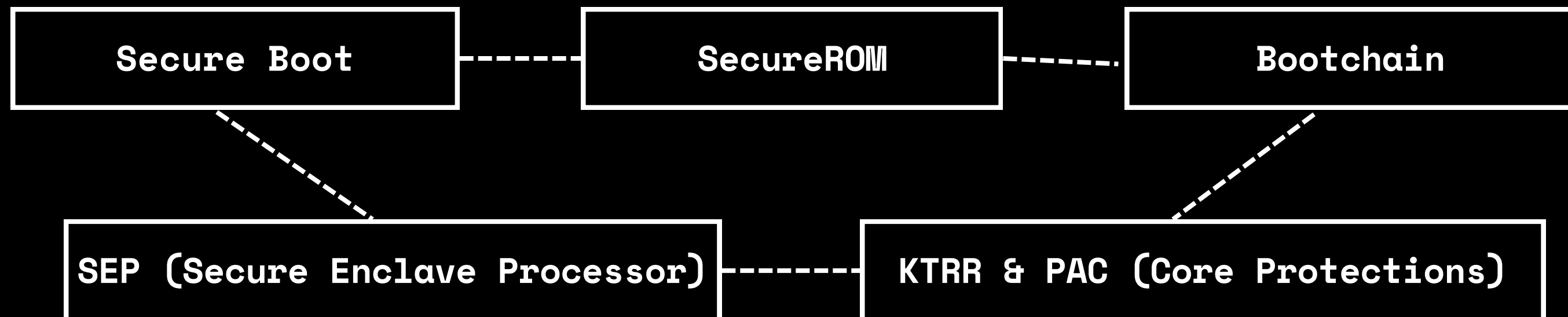
25-43209	Max CVSS	9.8
if-bounds access issue was addressed with improved bounds checking. This issue is fixed in macOS Sequoia 15.6, iOS 18.6 and iPadOS 18.6, tvOS 18.6, macOS Sonoma 14.7.7, watchOS 11.6, visionOS 2.6, macOS Ventura 13.7.7. Parsing a file may lead to an unexpected app termination.	EPSS Score	0.08%
Source: Apple Inc.	Published	2025-01-01
	Updated	2025-01-01

25-43186	Max CVSS	9.8
issue was addressed with improved memory handling. This issue is fixed in watchOS 11.6, iOS 18.6 and iPadOS 18.6, macOS Sequoia 15.6, macOS Sonoma 14.7.7, visionOS 2.6, macOS Ventura 13.7.7. Parsing a file may lead to an unexpected app termination.	EPSS Score	0.09%
Source: Apple Inc.	Published	2025-01-01
	Updated	2025-01-01

25-31281	Max CVSS	9.1
validation issue was addressed with improved memory handling. This issue is fixed in visionOS 2.6, tvOS 18.6, macOS Sequoia 15.6, iOS 18.6 and iPadOS 18.6. Processing a maliciously crafted file may lead to unexpected app termination.	EPSS Score	0.16%
Source: Apple Inc.	Published	2025-01-01
	Updated	2025-01-01

25-31229	Max CVSS	9.1
issue was addressed with improved checks. This issue is fixed in iOS 18.6 and iPadOS 18.6. Passcode may be read by VoiceOver.	EPSS Score	0.07%
Source: Apple Inc.	Published	2025-01-01
	Updated	2025-01-01

IOS ARCHITECTURE UNDER THE HOOD



SECURE BOOT THE ROOT OF TRUST

Hardware enforced trust anchor.

Each stage verifies the next
→ signed with Apple's keys.

Fail a check? → device refuses to boot.

SECUREROM: BURNED IN SILICON

First code that runs, stored in SoC.

Immutable → can't be patched with updates.

Verifies Low-Level Bootloader (LLB).

Vulnerabilities here = forever exploitable.

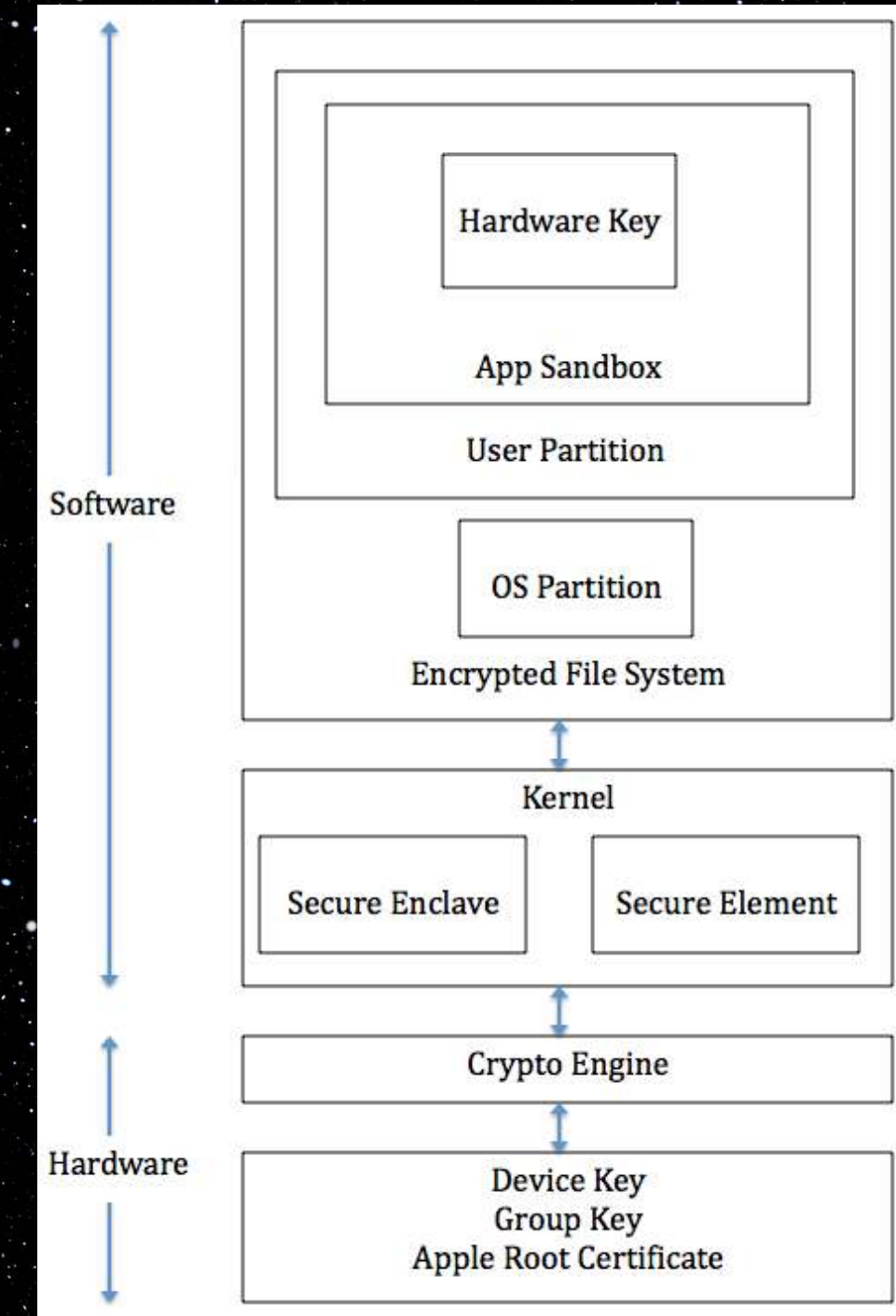
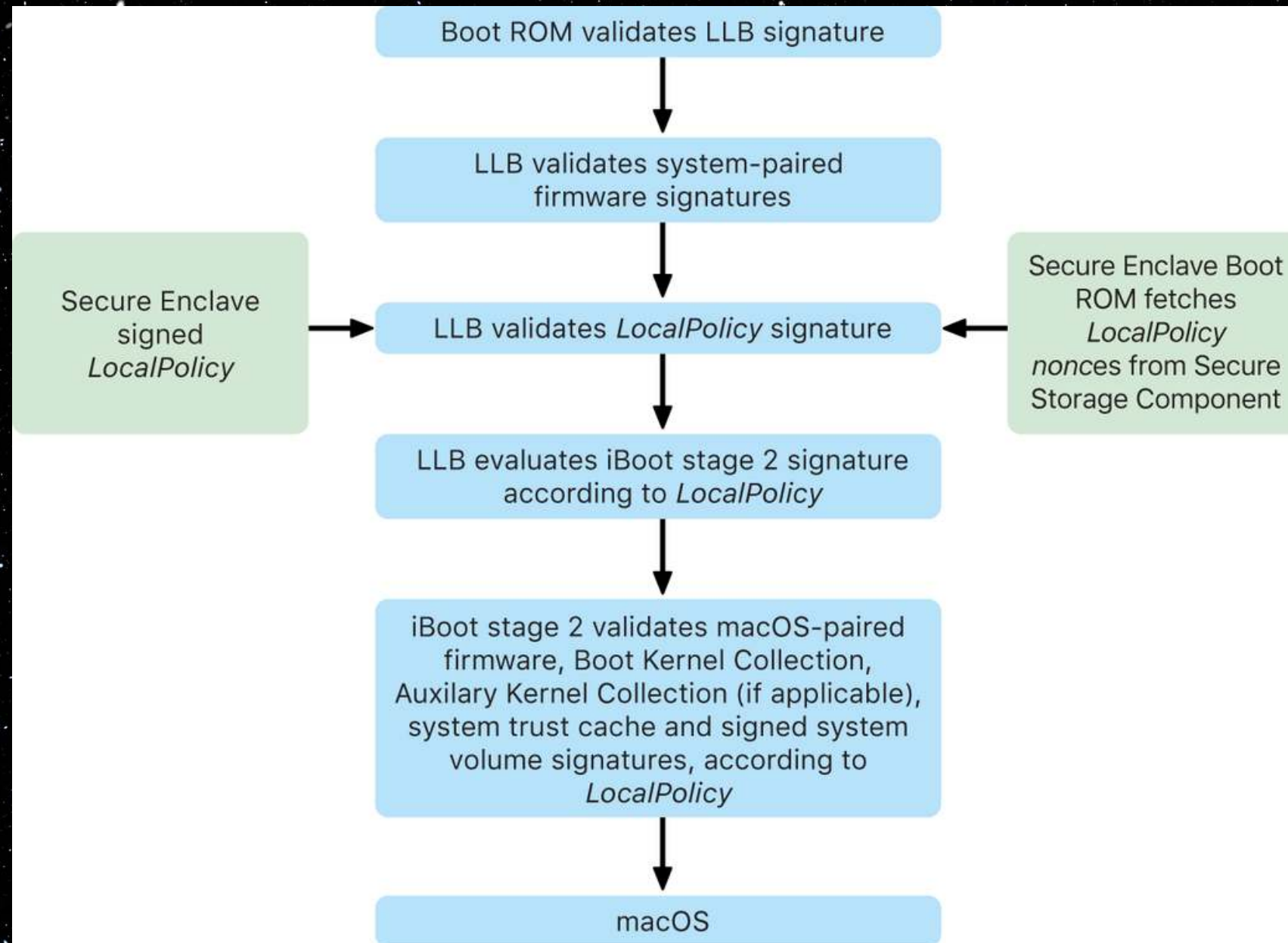
BOOTCHAIN CHAIN OF TRUST

SecureROM → LLB → iBoot → Kernel.

**Each verifies the signature of the
next.**

Break one link, control the chain.

BOOTCHAIN DIAGRAM



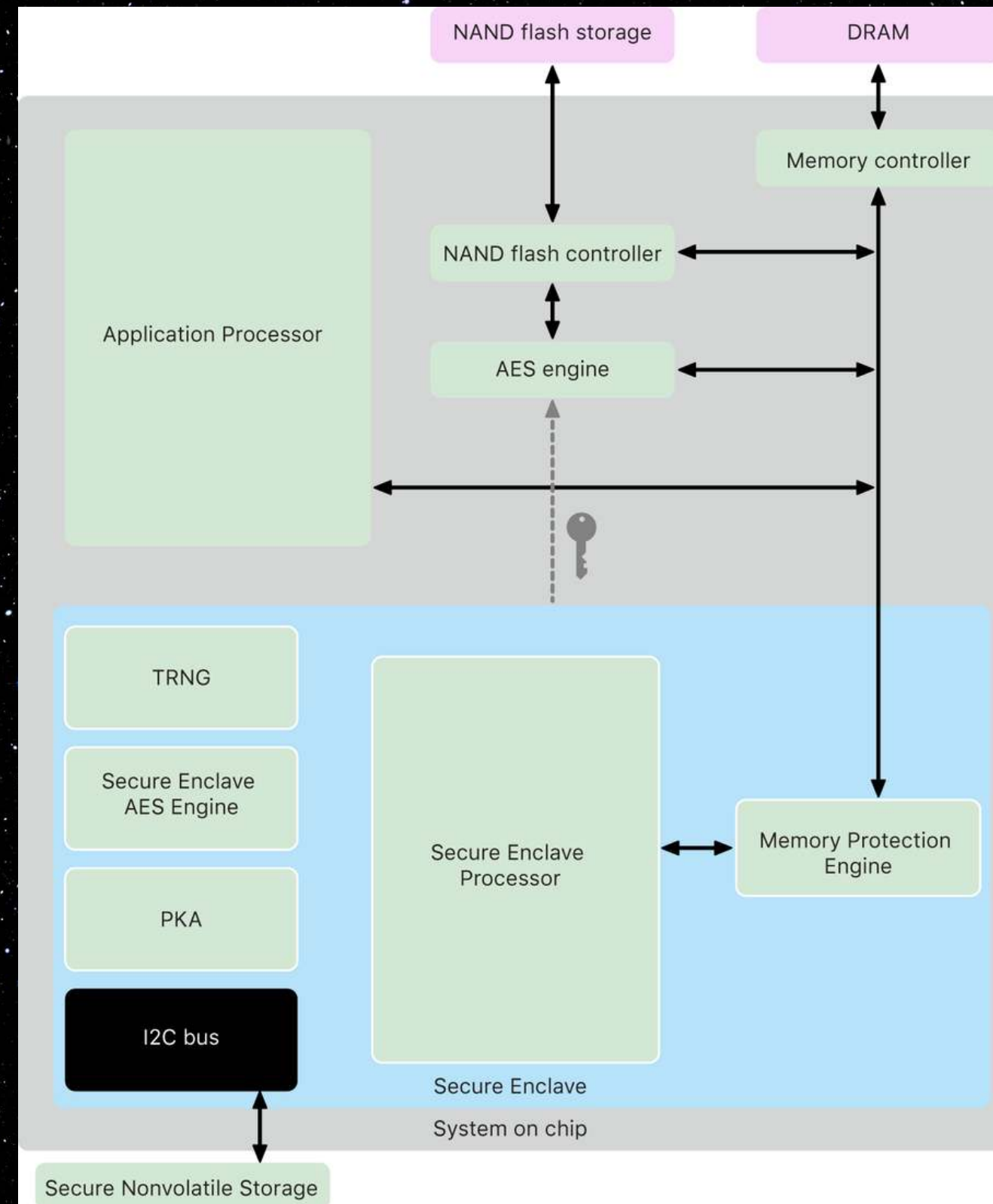
SEP THE IPHONE'S MINI BRAIN

**Handles cryptographic keys, biometrics,
payments.**

Isolated from main CPU → own firmware + RTOS.

Protects keybags, TouchID/FaceID data.

SEP DIAGRAM



DEMO TIME

SEP LOGS

TIM COOK CRYING

IN THE SECURE ENCLAVE

imgflip.com

KTRR & PAC CORE PROTECTIONS

KTRR: Kernel Text Read-Only Region.

Prevents kernel memory tampering.

PAC: Pointer Authentication Codes.

Blocks classic ROP exploitation.

Goal = raise bar for kernel exploits.

ENTITLEMENTS APPLE'S PERMISSION SLIP

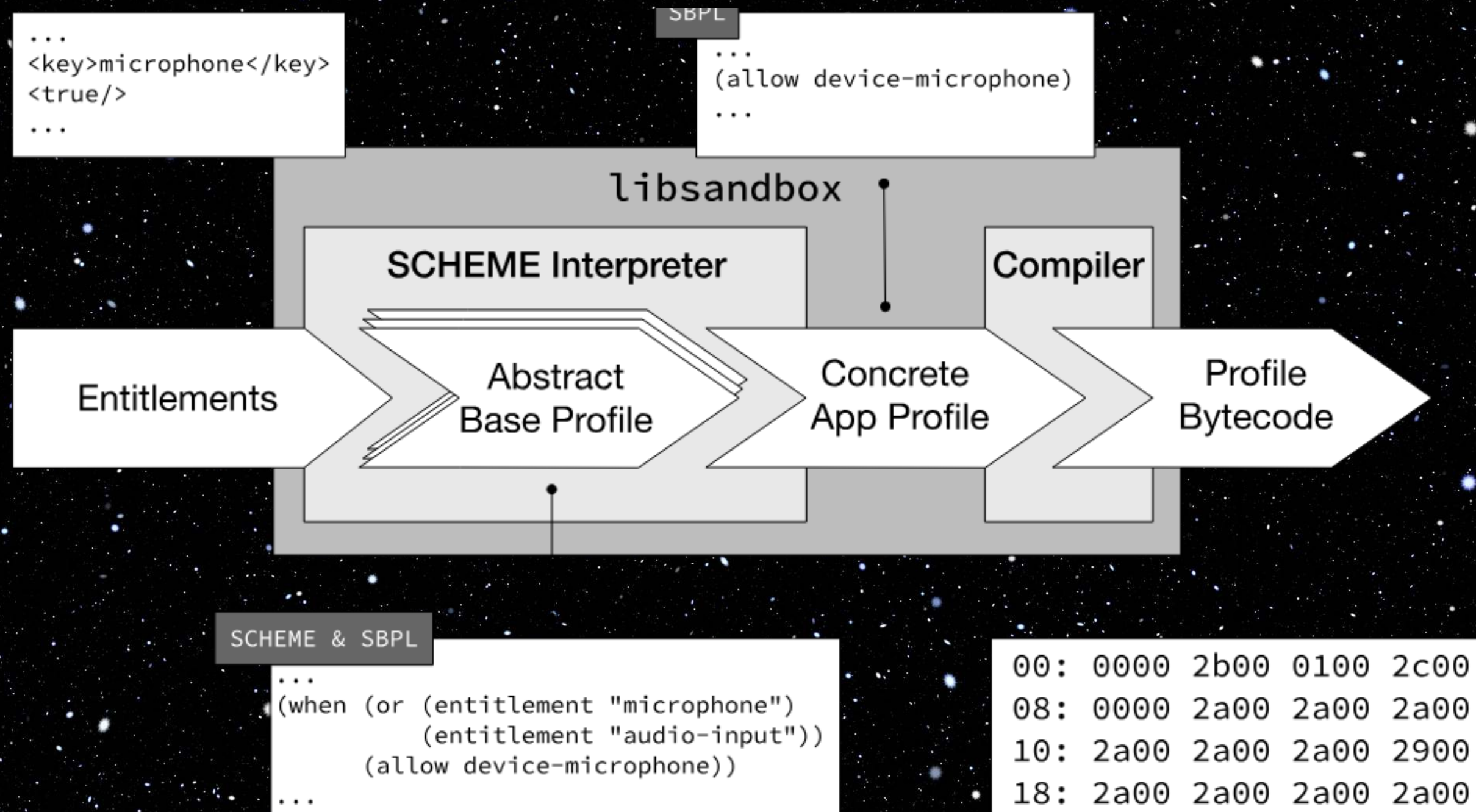
XML-like permissions baked into apps.

Controls access to private APIs/features.

Example

`com.apple.private.network.socket-delegate.`

ENTITLEMENTS - DIAGRAM



SANDBOXING

STAY IN YOUR LANE

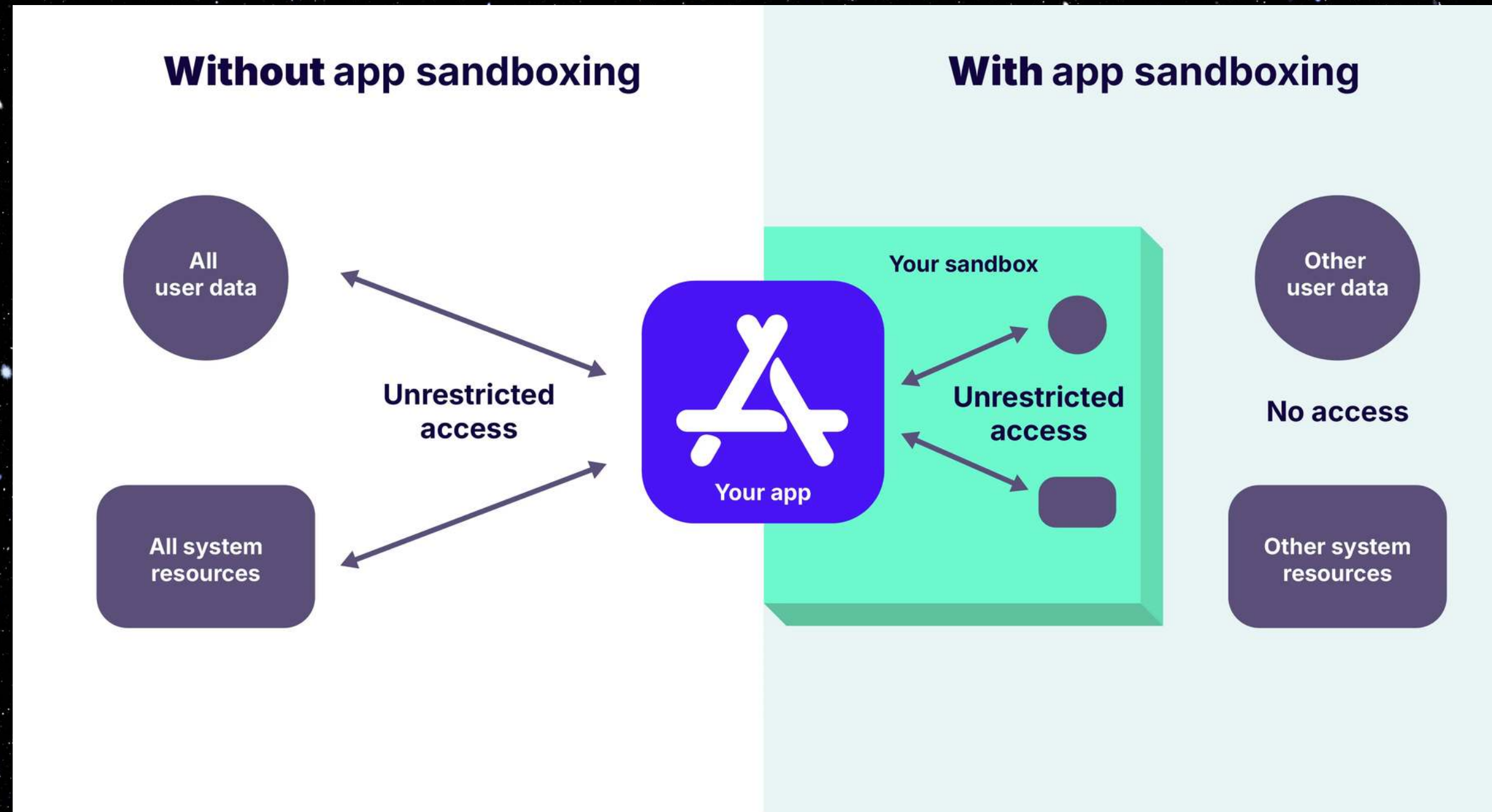
Apps run in sand boxed profiles.

Blocks lateral movement.

Example

Safari can't touch Mail's files.

SANDBOX DIAGRAM



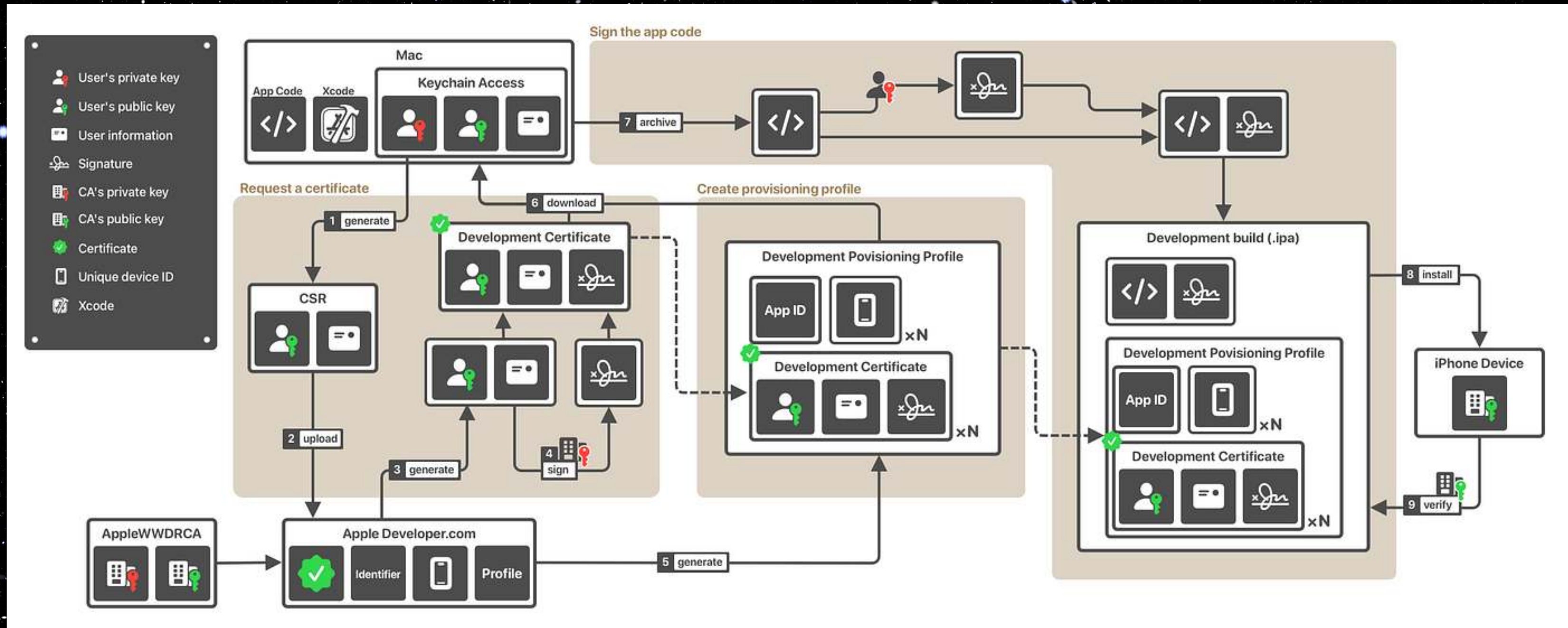
CODE SIGNING NO SIGNATURE, NO ENTRY

Every binary must be signed by Apple.

Enforced by AMFI
(Apple Mobile File Integrity).

Jailbreaks patch AMFI → unsigned code runs.

CODE SIGNING -DIAGRAM



DEMO TIME

BREAKING THE CHAIN

NOT USING RED STAR OS!

FOR IOS RESEARCH

ngflip.com

REVERSING APPLE'S LOGOS

WHERE FUSE LOCKS FAIL

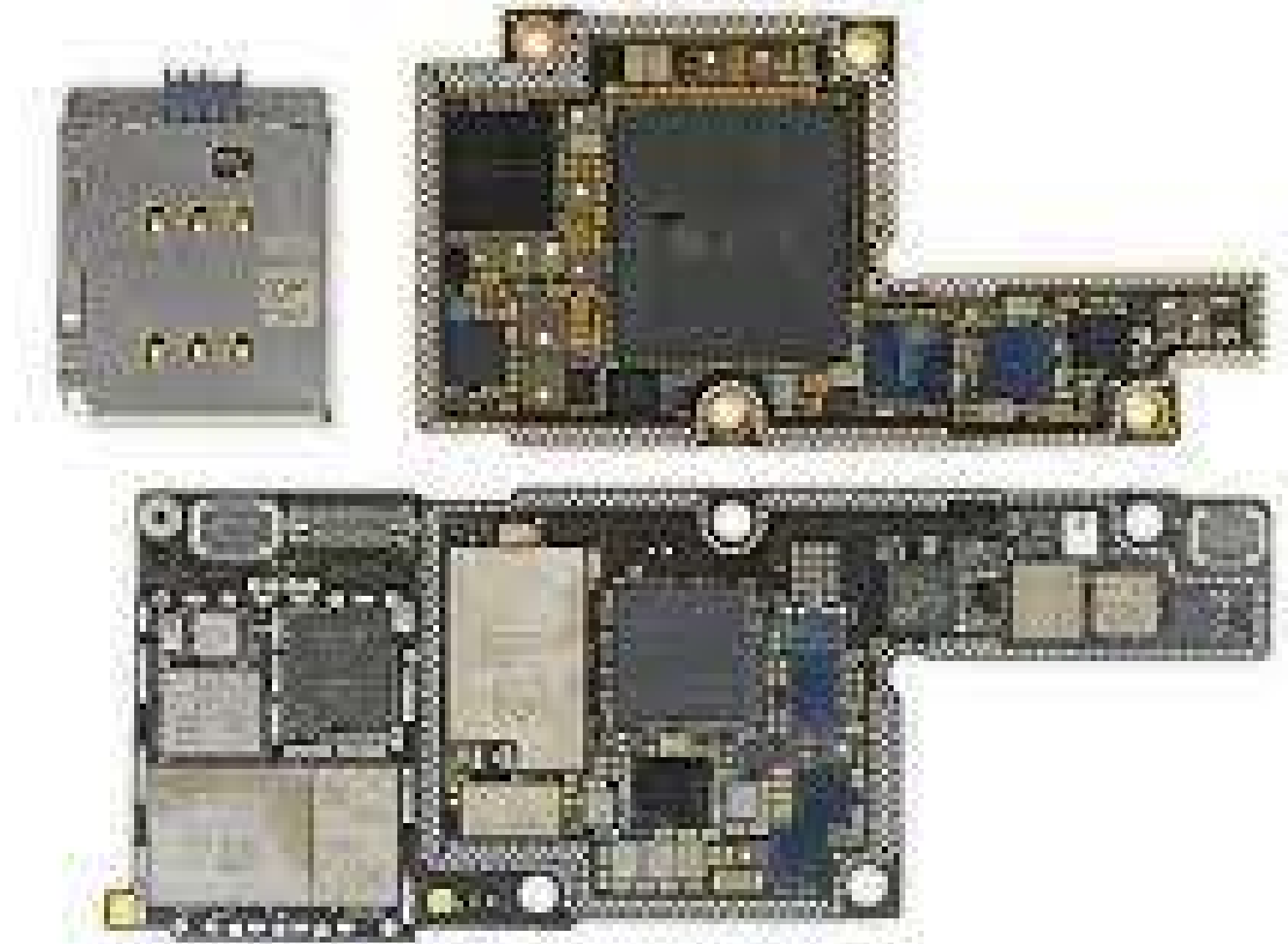
Fuse locks are hardware-enforced bits that are one time programmable

Designed to stop rollback/downgrade attacks.

Can be bypassed with hardware bugs or boot exploits.

Example
checkm8 (once in silicon, always in silicon).

FUSE LOGS - DIAGRAM



KERNEL LEVEL ATTACKS VIA GPU DRIVERS

GPU drivers = huge, complex, high priv
attack surface.

Memory corruption → kernel R/W.

Historically chained into persistence.



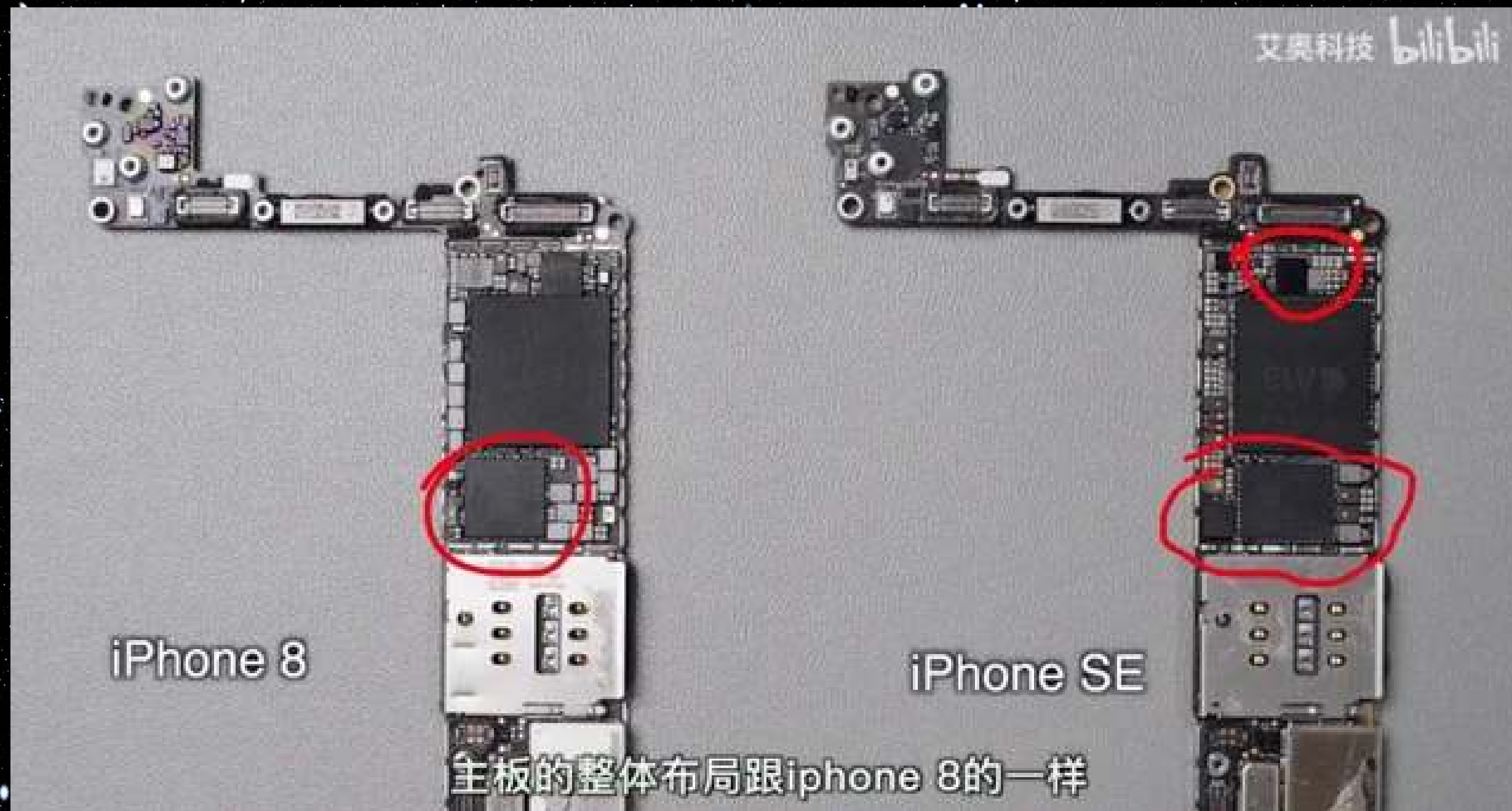
BASEBAND + RADIO STACK EXPLOIT CHAINS

Baseband runs its own RTOS, often
neglected.

Attack surface
SMS, Wi-Fi, LTE, Bluetooth.

Compromise → pivot into kernel space.

BASEBAND - DIAGRAM



ATTACKS AGAINST PAC (POINTER AUTH)

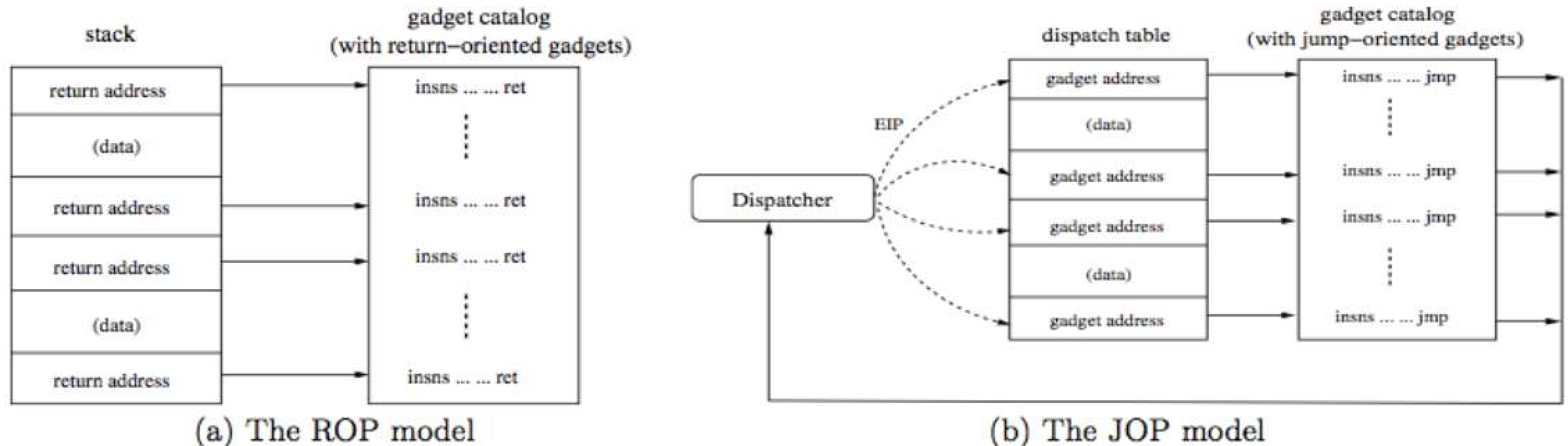
PAC

Pointer Authentication Codes → ARMv8.3 feature.

Stops classic ROP/JOP (Return/Jump Oriented Programming).

Bypasses exist
leak keys, brute force, logic bugs.

ROP/JOP DIAGRAM



DEMO TIME BREAKING THE LOCKS

BASED LINUX OS

FOR PENTESTING

imgflip.com

RED TEAMING THE WALLED GARDEN

ME WHEN APPLE PATCHES MY EXPLOIT.

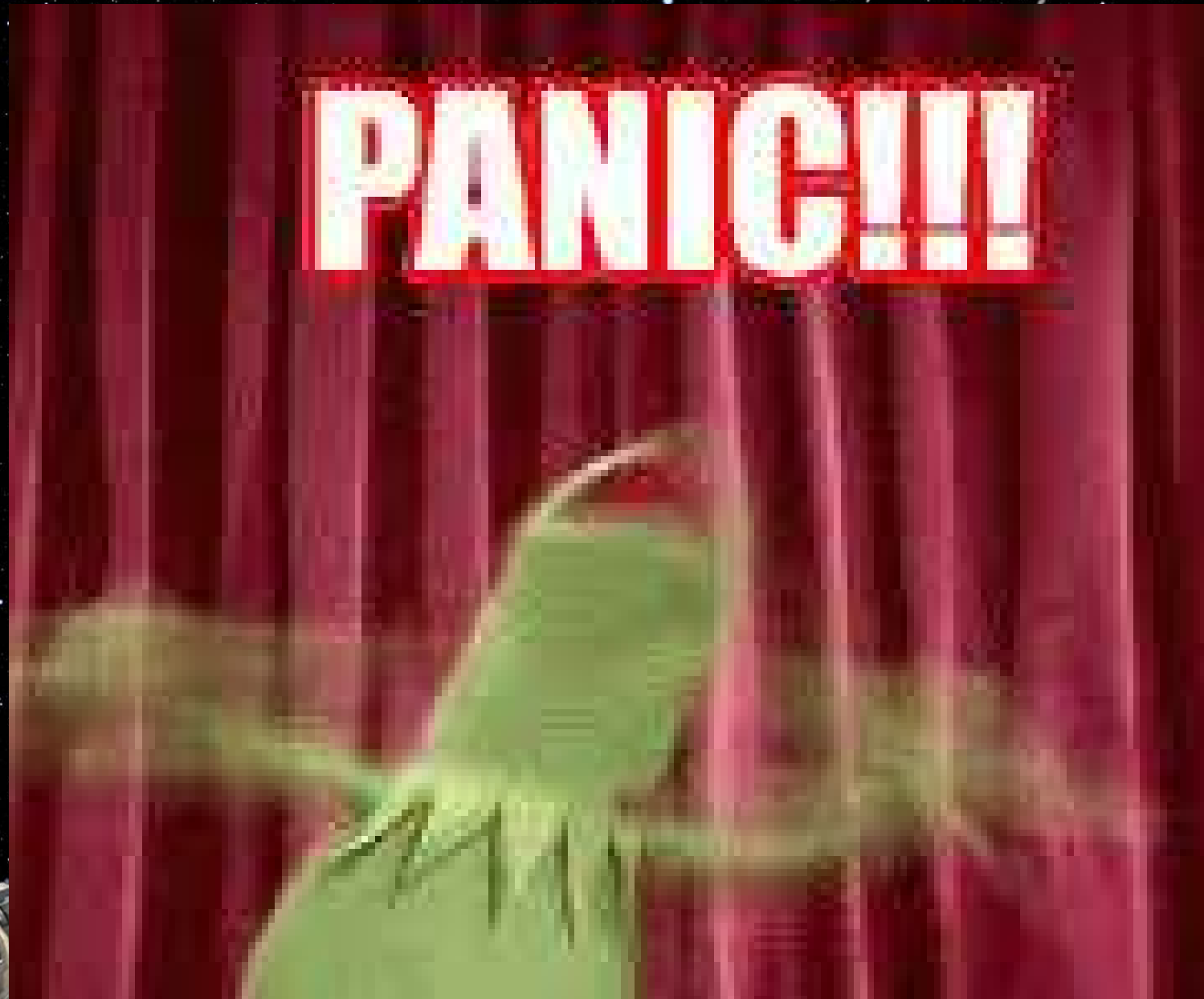


Bernie

IOS RESEARCHERS BE LIKE

**I am once again asking
for kernel panic logs**

DEMO TIME
KERNAL PANIC!



PRACTICAL PATHS TO PERSISTENT SURVEILLANCE

iOS persistence = the holy grail.

Common methods

Jailbreak/Persistence (launch daemons, dylib injection).

Enterprise provisioning abuse.

Exploiting update mechanisms.

Goal

Maintain foothold without triggering user suspicion.



JAILBREAK



Persistence Daemon

DEMO TIME

PERSISTENT IOS EXPLOIT



APPLE'S TELEMETRY & DFIR RESISTANCE

iOS phones constantly log: crash reports, power events, app usage.

Apple uses telemetry to detect compromised devices.

Forensics tools (Cellebrite, GrayKey) rely on these logs.

Red teamers wipe/poison logs → erase footprints.

COVERT IOS ATTACKS

Deliver payloads silently.

**Techniques
sideloading, enterprise certs, abusing MDM.**

Chaining with sandbox escapes = fully covert installs.

Used in advanced spyware (NSO, Predator, etc).

DEMO TIME

ANTI-FORENSICS IN ACTION

ANTI FORENSICS IRL

U CANT SEE ME!

FUTURE OUTLOOK

BREAKING THE BLACK BOX

SEP = isolated, mysterious, critical.

Fuzzing firmware = safe way to probe weaknesses.

Corellium → emulate & build testbed OSes.

THE BUG BOUNTY BLUES

Apple's bounty exists, but slow + low payout.

Researchers burned out by bad communication.

Result → vulns go private, defenders left behind.

THE REAL TARGET

iOS = most common “secure” device.

Android = more open, gets more research.

**Nation-states & spyware crews already own
iOS.**

JOIN THE FIGHT

Jailbroken iPhone = your first lab.

Corellium / DockerOSX = next step.

iOS Static & Dynamic App Analysis

Reverse entitlements & sandbox profiles.

Learn, share, meme and collab with the community.



UNBREAKING THE IPHONE

"It's not unhackable. It just needs more rebels"

**by
Jack Sessions**



RAP TIME!

